IT RISK ASSESSMENT

Analyse de Sécurité d'un Système de Transactions Bancaires

Dataset : Bank Transactions Dataset for Fraud Detection

50 000 enregistrements — 15 colonnes — Kaggle

Méthodologie appliquée

NIST Special Publication 800-30 Rev.1

Guide for Conducting Risk Assessments

[CHECK] [SEARCH] [COMM]

Prepare **Conduct** **Communicate**

[CAL]	**Année :** 2025–2026
[TAG]	**Type :** Hands-on Data – Détection d'Anomalies de Sécurité
[SHIELD]	**Domaine :** IT Risk / Cybersécurité Bancaire / AML
[DB]	**Source :** Kaggle – Bank Transactions Fraud Detection

Document confidentiel – Usage professionnel et pédagogique

[i] Résumé Exécutif

Ce document constitue la **documentation exhaustive** d'un projet d'évaluation des risques IT appliqué à un dataset de transactions bancaires réelles (50 000 enregistrements). Il suit rigoureusement la méthodologie **NIST SP 800-30 Rev.1** et s'articule autour du modèle de communication **OIR** (Observation – Impact – Recommandation).

Signaux détectés :	13 signaux internes + 9 scénarios croisés = **26 scénarios**
Risques critiques :	2 scénarios à score **25/25**
Exposition financière :	**+16 millions USD** identifiés
Intégrité du registre :	94,9% des enregistrements sans timestamp précis
Comptes compromis :	471 comptes Takeover + 355 comptes géo-impossibles

[!

Avertissement] Ce document est produit à des fins **pédagogiques et professionnelles**. Toutes les analyses sont basées sur un dataset synthétique. Les scénarios décrits sont des hypothèses argumentées, justifiées par les données observées.

Table des matières

1 Introduction et Cadre Méthodologique **6**
1.1 Contexte du projet 6
1.1.1 Nature et criticité du dataset 6
1.2 La méthodologie NIST SP 800-30 Rev.1 7
1.2.1 Présentation générale 7
1.2.2 Le calcul du risque selon NIST SP 800-30 7
1.3 Le modèle OIR – Communication des risques 9

2 Phase 1 – Préparer l'Évaluation **10**
2.1 Logique de la démarche 10
2.2 Le dataset comme artefact organisationnel 10
2.2.1 Structure du dataset 10
2.2.2 Les quatre surfaces d'exposition 12
2.3 Conditions prédisposantes 12
2.4 Questions génératrices vers la Phase 2 13

3 Phase 2 – Conduire l'Évaluation **14**
3.1 Méthodologie d'inspection 14
3.2 Les 13 Signaux de Détection (Scénarios Internes) 14
3.2.1 S1 – Brute Force (LoginAttempts > 3) 15
3.2.2 S2-A – Account Takeover Silencieux 16
3.2.3 S3-A – Device Compromis (Pivot Multi-Comptes) 17
3.2.4 S4-A – Structuration Financière (Merchant Flooding) 18
3.2.5 S5 – Anomalies de Durée de Session 18
3.2.6 S6-A – Défaillance des Timestamps (CRITIQUE) 19
3.2.7 S7 – Violation du Solde (CRITIQUE) 20
3.2.8 S8-A – Layering / Blanchiment (Credit vers Debit rapide) 21
3.2.9 S9-A – Account Farm / Botnet (IP Multi-Comptes) 21
3.2.10 S10-A – Card Testing (Micro-transactions moins de 10dollar) . . . 22
3.2.11 S11-A – Money Mule Receiver (Comptes Credit-Only) 22
3.2.12 S12-A – Impossibilité Géographique (2 Villes, Même Jour) 23
3.2.13 S13-A – Anomalie Démographique (Student + Montants Élevés) . 23

3.3 Les 9 Scénarios Croisés 24
3.3.1 X4 – Le multiplicateur global : Timestamps × Tous 25

4 Phase 3 – Communiquer les Résultats 26
4.1 La Matrice de Risques 5×5 26
4.1.1 Tableau récapitulatif des 26 scénarios 26
4.2 Le Modèle OIR – Rapport de Communication 28
4.2.1 OIR-1 : Défaillance des Timestamps 28
4.2.2 OIR-2 : Account Takeover et Impossible Geography 29
4.2.3 OIR-3 : Structuration Financière et Blanchiment 29
4.2.4 OIR-4 : Botnet et Account Farm 30
4.2.5 OIR-5 : Signaux Élevés (Brute Force, Card Testing, Bots) 30

5 Livrables et Guide de Reproduction 32
5.1 Architecture du fichier Excel 32
5.2 Guide de reproduction pas à pas 32
5.2.1 Étape 1 – Préparer le dataset (Onglet 1) 32
5.2.2 Étape 2 – Créer les colonnes auxiliaires (Onglet 1, colonnes P à AF) 33
5.2.3 Étape 3 – Vérifier les volumes 34

6 Glossaire et Annexes 35
6.1 Glossaire des termes et notions 35
6.2 Tableau de synthèse final – Exposition financière totale 37
6.3 Références réglementaires et bibliographiques 37

CHAPITRE 1

Introduction et Cadre Méthodologique

1.1 Contexte du projet

Ce projet s'inscrit dans le cadre d'un exercice pratique (*Hands-on Data*) de détection d'anomalies de sécurité dans un système bancaire numérique. Plutôt que de se limiter à la détection de fraude financière au sens strict, l'approche adoptée ici consiste à **traquer les signaux informatiques suspects** – ce qui en fait un exercice à la croisée de la cybersécurité, de la conformité AML (*Anti-Money Laundering*) et de la gouvernance des données.

[DB

Le Dataset] **Source :** Kaggle – *Bank Transactions Dataset for Fraud Detection*
Volume : 50 000 enregistrements | 15 colonnes | 0 valeur manquante
Nature : Registre général de transactions bancaires simulant l'activité réelle

1.1.1 Nature et criticité du dataset

Ce dataset n'est pas simplement un fichier de données. C'est un **artefact organisationnel critique** qui :

- Est **créé automatiquement** à chaque nouvelle transaction (mode écriture réservé au système bancaire)
- **Justifie chaque mouvement de fonds** – entrées et sorties de comptes réels
- Est **consulté périodiquement lors d'audits** de conformité régulatoire
- Supporte des **décisions critiques** prises par les *stakeholders*, investisseurs et régulateurs
- Constitue une **pièce probante** en cas de litige ou procédure judiciaire

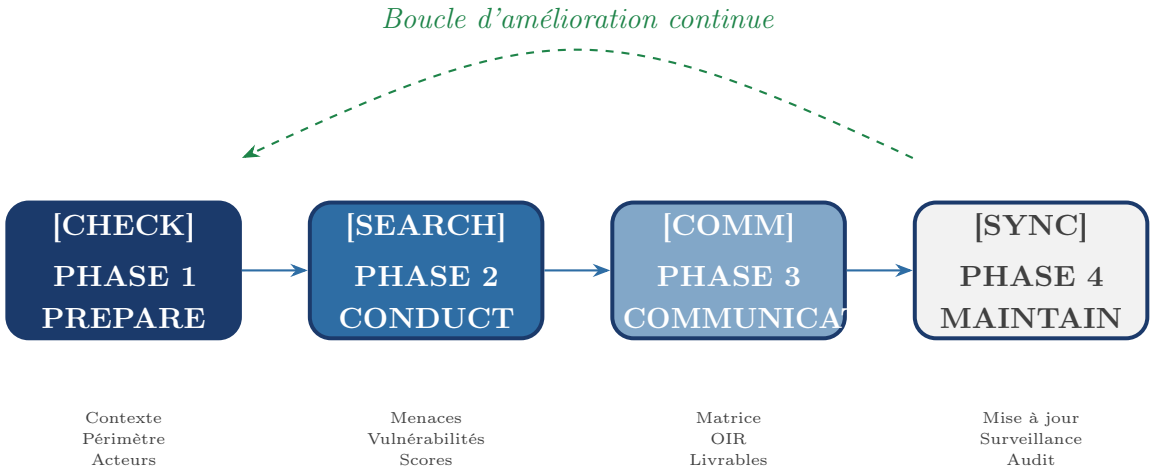
[!

Implication directe] Si ce registre est altéré, corrompu ou consulté sans autorisation, toutes les décisions basées sur son contenu sont compromises. C'est un actif de **haute valeur** et donc une cible de haute valeur pour les attaquants.

1.2 La méthodologie NIST SP 800-30 Rev.1

1.2.1 Présentation générale

Le **NIST SP 800-30** (*National Institute of Standards and Technology – Special Publication 800-30, Revision 1*) est le guide de référence américain pour la conduite d'évaluations des risques dans les systèmes d'information.

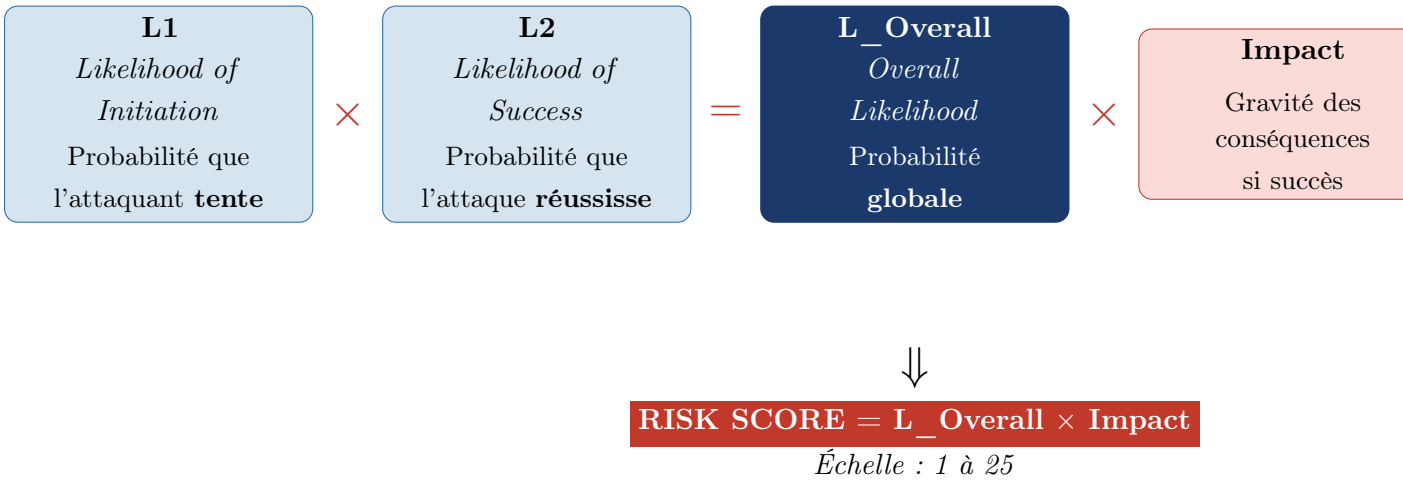


[i

Note importante] Dans le cadre de ce projet, nous avons appliqué les **trois premières phases**. La Phase 4 (Maintain) n'est pas traitée ici car la matrice de risques produite constitue le livrable final de démonstration. Un projet réel inclurait cette phase pour assurer la mise à jour continue de l'évaluation.

1.2.2 Le calcul du risque selon NIST SP 800-30

L'originalité du NIST SP 800-30 réside dans la décomposition du *Likelihood* (probabilité) en **trois composantes distinctes**, contrairement aux approches simplistes à une seule probabilité.



L'échelle de scoring (1 à 5)

Score	Niveau	Pour L1 / L2 / L_Overall	Pour l'Impact
5	Very High	Quasi-certain / Déjà réalisé	Catastrophique
4	High	Très probable	Significatif
3	Moderate	Possible	Modéré
2	Low	Peu probable	Mineur
1	Very Low	Rare	Négligeable

Table de combinaison L1 × L2 → L_Overall

Cette table, issue du NIST SP 800-30, permet de calculer le *Likelihood Overall* à partir des deux composantes :

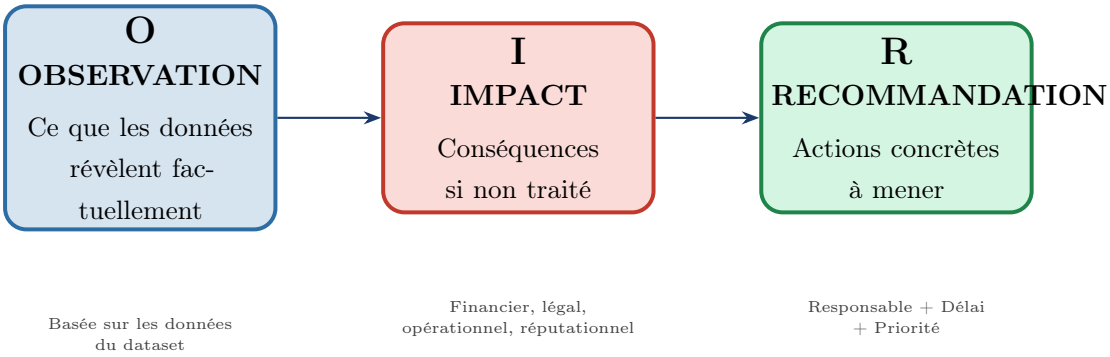
L2 \ L1	VH(5)	H(4)	M(3)	L(2)	VL(1)
Very High (5)	**5**	**5**	**4**	**3**	**2**
High (4)	**5**	**4**	**3**	**2**	**1**
Moderate (3)	**4**	**3**	**3**	**2**	**1**
Low (2)	**3**	**2**	**2**	**1**	**1**
Very Low (1)	**2**	**1**	**1**	**1**	**1**

Seuils de la matrice de risques 5×5

Score	Niveau	Action requise
20 – 25	**Critique**	Action immédiate (0–72h)
15 – 19	**Très Élevé**	Action urgente (<1 semaine)
10 – 14	**Élevé**	Haute priorité (<1 mois)
5 – 9	**Modéré**	Planification (<3 mois)
1 – 4	**Faible**	Surveillance

1.3 Le modèle OIR – Communication des risques

Le modèle **OIR** (Observation – Impact – Recommandation) est le framework de communication adopté pour présenter les résultats à différentes audiences.



Audiences cibles

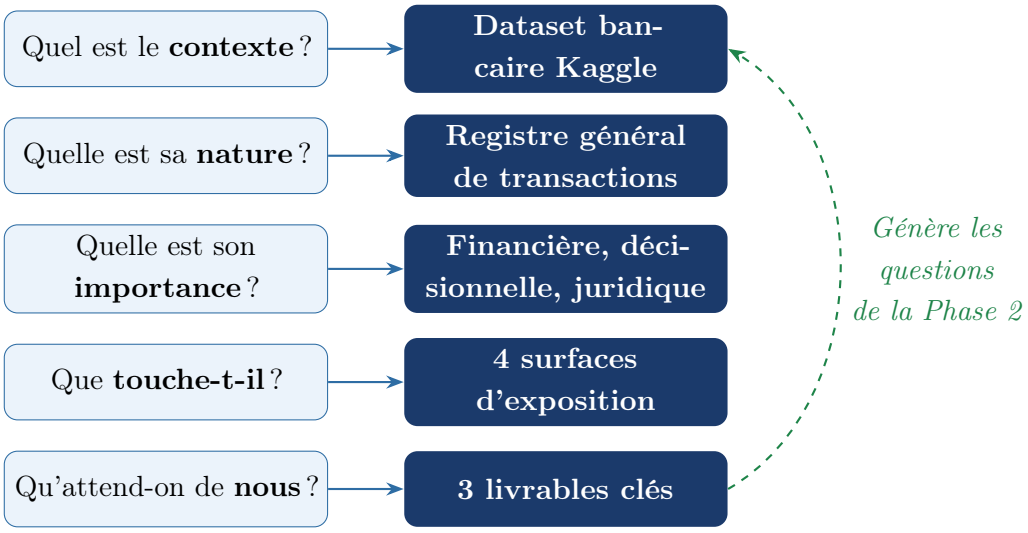
Seniors IT / RSSI :	Volet technique – signaux, formules, scores
Directeurs / Décideurs :	Volet exécutif – risques prioritaires, urgences
Auditeurs / Régulateurs :	Volet conformité – preuves, recommandations

CHAPITRE 2

Phase 1 – Préparer l'Évaluation

2.1 Logique de la démarche

La Phase 1 répond à une question fondamentale : **comprendre avant d'agir**. Avant toute inspection du dataset, nous devons établir le contexte, identifier les acteurs, et définir le périmètre. Cette étape est analogue à celle d'un auditeur qui lit les statuts d'une entreprise avant d'entrer dans ses locaux.



2.2 Le dataset comme artefact organisationnel

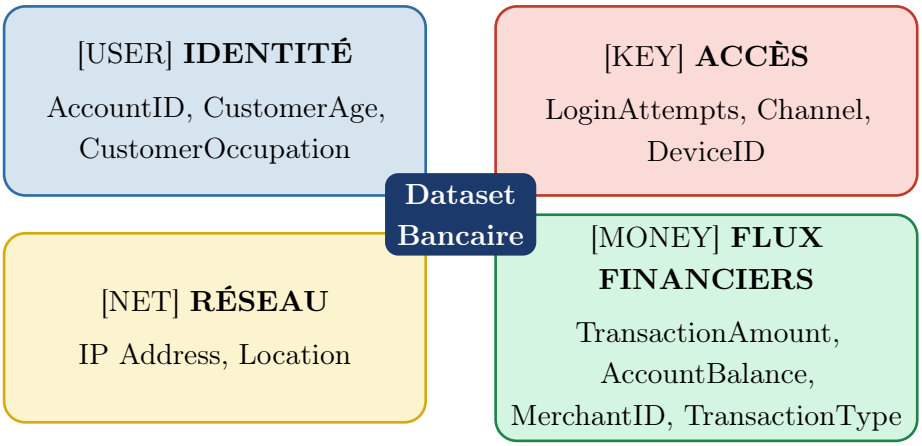
2.2.1 Structure du dataset

Table 2.1: Métadonnées du dataset – Analyse de criticité

Colonne	Type	Signification cachée et criticité
TransactionID	Texte	Référencement unique. Doit être séquentiel et sans doublon. Un gap dans la séquence = transaction supprimée.
AccountID	Texte	Identifiant du compte. Pivot de toutes les corrélations. Un même compte dans des conditions anormales = compromission.
TransactionAmou	Nombre	Montant transféré. Débit > Solde = impossible sans découvert autorisé.
TransactionDate	Date/Heure	**Critique** : l'heure dit souvent plus que la date. Transactions nocturnes, timestamps absents = faille d'audit trail.
TransactionType	Texte	Debit / Credit. Un compte avec uniquement des Credits = Money Mule potentiel.
Location	Texte	Ville. Même compte dans 2 villes le même jour = impossibilité géographique.
DeviceID	Texte	Identifiant du device. Doit être associé à un seul compte. Multi-comptes = device compromis.
IP Address	Texte	Adresse réseau. Une IP accédant à 13 comptes = botnet confirmé.
MerchantID	Texte	Marchand destinataire. Rafales vers un même marchand = structuration AML.
Channel	Texte	ATM / Online / Branch. Détermine le vecteur d'attaque possible.
CustomerAge	Nombre	Âge du titulaire. Cohérence avec l'occupation à vérifier.
CustomerOccupatio	Texte	Student / Doctor / Retired / Engineer. Cohérence avec les montants.

Colonne	Type	Signification cachée et criticité
TransactionDurati	Nombre	Durée en secondes. Durée fixe répétée = signature de bot.
LoginAttempts	Nombre	De 1 à 5. > 3 = signal Brute Force.
AccountBalance	Nombre	Solde après transaction. Solde figé = possible manipulation du registre.

2.2.2 Les quatre surfaces d'exposition



2.3 Conditions prédisposantes

Canal	Type d'exposition	Risques prédisposants
Online	Cyber directe	Credential stuffing, BF automatisé, MITM, session hijacking
ATM	Physique	Vol de carte, skimming, tentatives PIN, retraits nocturnes
Branch	Humaine	Ingénierie sociale, accès interne non autorisé, complicité employé

2.4 Questions génératrices vers la Phase 2

La Phase 1 génère naturellement les questions qui pilotent l'analyse. C'est le principe fondateur de cette démarche : *chaque domaine est la réponse aux questions du domaine précédent.*

Q1. Quels `AccountID` ont `LoginAttempts > 3` ? → *Signal Brute Force*

Q2. Un même `AccountID` apparaît-il avec des `Location` différentes + devices différents + IPs différentes ? → *Account Takeover*

Q3. Un même `DeviceID` apparaît-il sur plusieurs `AccountID` distincts ? → *Device compromis*

Q4. Des `MerchantID` reçoivent-ils des flux répétés en rafale ? → *Structuration AML*

Q5. La composante horaire de `TransactionDate` est-elle fiable ? → *Intégrité audit trail*

Q6. Le `TransactionAmount` dépasse-t-il l'`AccountBalance` en Debit ? → *Violation de solde*

CHAPITRE 3

Phase 2 – Conduire l'Évaluation

3.1 Méthodologie d'inspection

L'inspection du dataset suit une logique précise : pour chaque métadonnée, on évalue les possibilités **du plus anormal au plus normal**, puis on construit des filtres de recherche pour les confirmer ou infirmer sur les 50 000 enregistrements.

[TOOLS

Outil utilisé : Microsoft Excel] Le choix d'Excel est dicté par la nature du dataset. C'est un fichier `.xlsx` – donc l'outil adapté est Excel. Les filtres, formules et tableaux croisés dynamiques (TCD) constituent l'arsenal d'investigation. Chaque requête est documentée et reproductible.

3.2 Les 13 Signaux de Détection (Scénarios Internes)

Nomenclature des colonnes auxiliaires

Signal	Colonne	En-tête	Score	Signal	Colonne	En-tête	Score
S1-A	P	BF_ATM	16/25	S7-A	Y	BAL_VIOLATION	25/25
S1-B	Q	BF_Online	16/25	S7-B	Z	OVD_BF	16/25
S1-C	R	BF_Branch	12/25	S8-A	AA	LAYERING	20/25
S2-A	S	TAKEOVER	20/25	S9-A	AB	IP_FARM	20/25
S3-A	T	DEV_MULTI	16/25	S10-A	AC	CARD_TEST	16/25
S4-A	U	MERCH_FLOOD	20/25	S11-A	AD	MULE_RECEIVER	15/25
S5-A	V	BOT_COURT	16/25	S12-A	AE	GEO_IMPOSS	20/25
S5-B	W	SESSION_LONGUE	12/25	S13-A	AF	STU_ANOMALIE	12/25
S6-A	X	TS_MANQUANT	25/25				

3.2.1 S1 – Brute Force (LoginAttempts > 3)

Définition et justification

Le **Brute Force** est une technique d'attaque où un acteur tente systématiquement des combinaisons de credentials sur un `AccountID` qu'il ne possède pas légitimement. Dans ce dataset, un LoginAttempts élevé **combiné à une transaction complétée** prouve que le système n'a pas bloqué l'accès au seuil critique.

[!

Distinction fondamentale] Un `LoginAttempts > 3` **avec transaction aboutie** = l'attaquant a réussi malgré les tentatives. C'est le scénario le plus grave car il prouve l'absence de contrôle effectif de blocage.

Résultats des filtres

Signal	Canal	Volume total	Cas LA=5+Debit	Score	Niveau
S1-A	ATM	432	173	16/25	Élevé
S1-B	Online	391	80	16/25	Élevé
S1-C	Branch	482	206	12/25	Modéré
TOTAL	Tous	**1 305**	**459**	–	–

Formules Excel (français)

S1-A – ATM Brute Force (Colonne P)

```
=SI(ET(J3="ATM";N3>3;E3="Debit");"[!] BF_ATM";"OK")
```

S1-B – Online Brute Force (Colonne Q)

```
=SI(ET(J3="Online";N3>3);"[!] BF_Online";"OK")
```

S1-C – Branch Brute Force (Colonne R)

```
=SI(ET(J3="Branch";N3>3);"[!] BF_Branch";"OK")
```

Vérification : `=NB.SI(P:P;"ALERT BF_ATM")` → résultat attendu : **173**

Scoring détaillé

Signal	L1	L2	L_Overall	Impact	Score
S1-A ATM BF	4 (High)	4 (High)	4	4 (Significatif)	**16/25 Élevé**
S1-B Online BF	5 (V.High)	3 (Modérate)	4	4 (Significatif)	**16/25 Élevé**
S1-C Branch BF	3 (Modérate)	3 (Modérate)	3	4 (Significatif)	**12/25 Modéré**

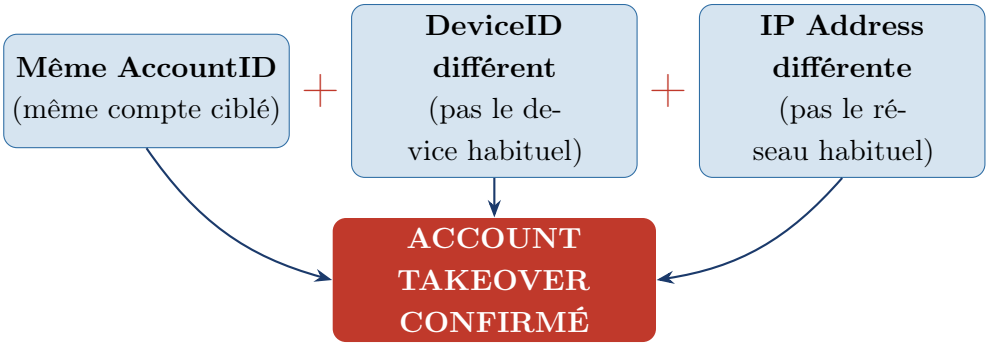
Justification L1 S1-B = 5 : Le credential stuffing est l'attaque #1 contre les banques en ligne. Des outils gratuits existent, des millions de credentials circulent sur le dark web. Coût pour l'attaquant : quasiment nul.

Justification L1 S1-C = 3 : Requiert une présence physique ou un accès interne. Plus contraignant que l'Online. Mais le volume paradoxalement le plus élevé (482 cas) suggère un problème systémique à investiguer.

3.2.2 S2-A – Account Takeover Silencieux

Définition stricte

L'Account Takeover est la compromission d'un compte par un tiers non autorisé. Pour être qualifié comme tel, **trois conditions simultanées sont requises** :



[i

Si même device + même IP] → Simple oubli de mot de passe, **pas un Takeover**. La distinction est essentielle pour éviter les faux positifs.

Résultats

Indicateur	Valeur	Signification
Comptes multi-device ET multi-IP	**471**	Takeovers potentiels
Record de devices distincts	**12** (AC00202, AC00363)	12 identités d'accès distinctes
Comptes cumulant BF + Takeover	**59**	Priorité absolue d'investigation
Exposition financière (59 comptes)	**1 584 876 $**	Debit exposé

S2-A – Account Takeover (Colonne S)

```
=SI(NB.SI.ENS($B$3:$B$50001;B3;$G$3:$G$50001;"<>"&G3)>0;"ALERT
TAKEOVER";"OK")
```

Scoring : L1=4 | L2=4 | L_Overall=4 | Impact=5 → **20/25** Très Élevé

3.2.3 S3-A – Device Compromis (Pivot Multi-Comptes)

Un DeviceID ne devrait être associé qu'à un seul compte. Quand un même device apparaît sur plusieurs comptes, deux scénarios sont possibles :

- Device **infecté par un malware** (spyware, RAT) utilisé à l'insu du propriétaire
- Device **volé** et utilisé pour accéder à d'autres comptes
- Device **délibérément partagé** dans une opération organisée

Résultat : 609 devices sur plusieurs comptes. D000697 : 9 locations, 9 comptes, 8 IPs.

S3-A – Device Multi-Comptes (Colonne T)

```
=SI(NB.SI.ENS($G$3:$G$50001;G3;$B$3:$B$50001;"<>"&B3)>0;"[!]
DEV_MULTI";"OK")
```

Scoring : L1=3 | L2=4 | L_Overall=4 | Impact=4 → **16/25** Élevé

3.2.4 S4-A – Structuration Financière (Merchant Flooding)

Définition

La **structuration** (ou *smurfing*) consiste à fragmenter un montant important en petites transactions répétées vers un même marchand pour rester sous les seuils de détection AML. C'est une infraction pénale dans la quasi-totalité des juridictions.

Résultats

AccountID	MerchantID	Transactions	Total $	Canaux
AC00398	M091	42	31 072	2
AC00011	M007	45	18 546	2
AC00241	M028	57	7 268	2
AC00425	M097	47	14 974	2
TOTAL	–	**2 446 paires**	**~14,5M$**	–

S4-A – Merchant Flooding (Colonne U)

```
=SI(NB.SI.ENS($B$3:$B$50001;B3;$I$3:$I$50001;I3)>5;"[!]
MERCH_FLOOD";"OK")
```

Scoring : L1=4 | L2=4 | L_Overall=4 | Impact=5 → **20/25** Très Élevé

3.2.5 S5 – Anomalies de Durée de Session

S5-A – Bot Automatisé (durée anormalement courte)

Une durée de transaction identique et très courte, répétée plusieurs fois sur le même compte, est une **signature non humaine** – un bot effectue une transaction toujours dans exactement le même intervalle.

Résultat : 78 cas avec durée $\leq$ 24s + LoginAttempts > 3 + Debit. AC00108 : exactement **12 secondes** répétées sur plusieurs sessions distinctes.

S5-A – Bot Automatisé (Colonne V)

```
=SI(ET(M3<=24;N3>3;E3="Debit");"[!] BOT_COURT";"OK")
```

Scoring : L1=4 | L2=3 | L_Overall=4 | Impact=4 → **16/25** Élevé

S5-B – Session Longue Online (MITM suspect)

Une session Online dépassant 292 secondes (P99 du dataset) peut indiquer une interception de session (*Man-in-the-Middle*) ou une exfiltration lente.

Résultat : 373 cas. Majorité Online.

S5-B – Session Longue (Colonne W)

```
=SI(ET(M3>292;J3="Online");"[!] SESSION_LONGUE";"OK")
```

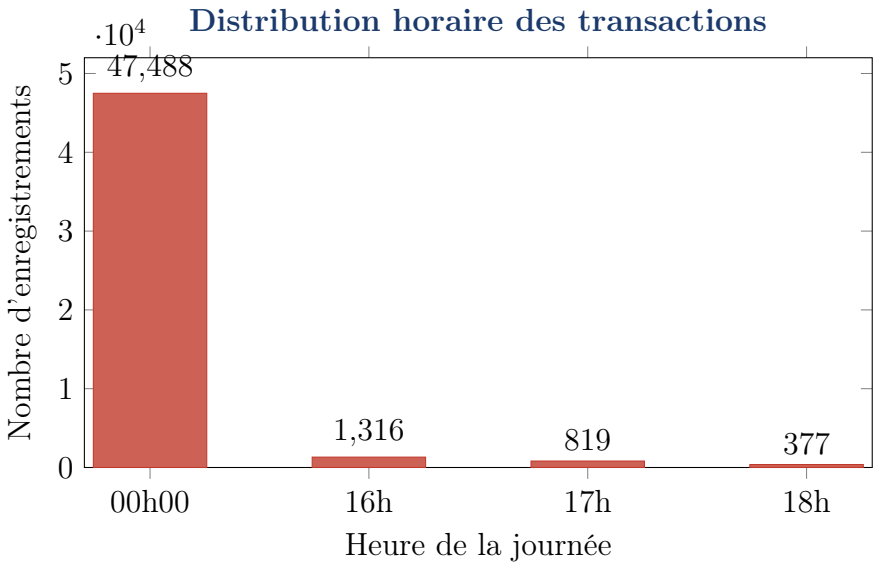
Scoring : L1=2 | L2=3 | L_Overall=3 | Impact=4 → **12/25** Modéré

3.2.6 S6-A – Défaillance des Timestamps (CRITIQUE)

La révélation majeure du dataset

[CRIT

Découverte critique] **47 488 sur 50 000 enregistrements (94,9%)** ne disposent d'aucune heure de transaction précise. La composante horaire de `TransactionDate` est absente et parsée à `00:00:00` par défaut. Seuls 2 512 enregistrements ont une heure réelle (16h, 17h ou 18h uniquement).



Conséquences par canal

Canal	Sans heure	Implication
ATM	15 719	Retraits non localisables dans le temps
Branch	16 410	Impossible de vérifier si l'agence était ouverte
Online	15 359	Connexions simultanées indétectables

S6-A – Timestamp manquant (Colonne X)

```
=SI(TEXTE(D3;"hh:mm:ss")="00:00:00";"[!] TS_MANQUANT";"OK")
```

Vérification : `=NB.SI(X3:X50001;"ALERT TS_MANQUANT")/50000` → résultat attendu : **0,949 (94,9%)**

Scoring : L1=5 | L2=5 | L_Overall=5 | Impact=5 → **25/25** CRITIQUE

3.2.7 S7 – Violation du Solde (CRITIQUE)

S7-A – Debit > AccountBalance

Indicateur	Valeur	Signification
Transactions Debit > Solde	**1 708**	Impossible sans découvert autorisé
Cas AC00161	Solde figé à **421,93$**	Possible manipulation du registre

S7-A – Violation de Solde (Colonne Y)

```
=SI(ET(E3="Debit";D3>O3);"[!] BAL_VIOLATION";"OK")
```

Scoring : L1=4 | L2=5 | L_Overall=5 | Impact=5 → **25/25** CRITIQUE

S7-B – Overdraft + Brute Force (double violation)

34 enregistrements cumulent **Debit** > **Balance** ET **LoginAttempts** > 3. Double défaillance simultanée : contrôle d'accès ET contrôle de solde absents.

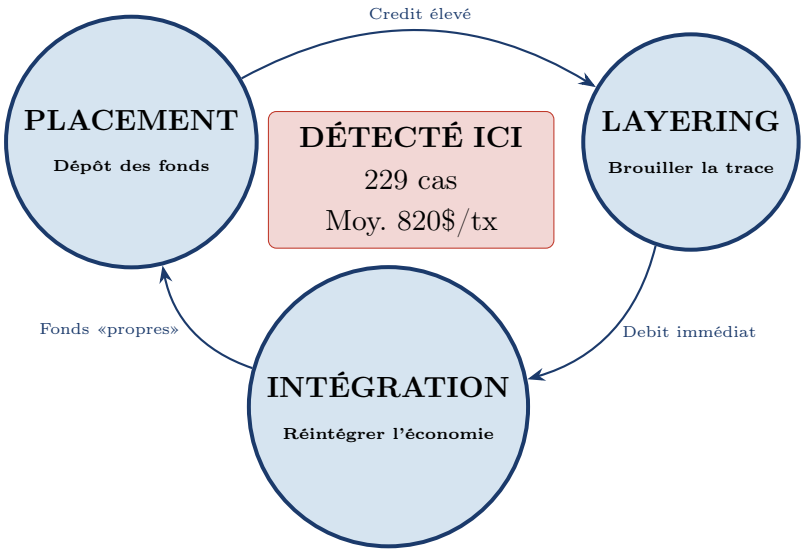
S7-B – Overdraft + BF (Colonne Z)

```
=SI(ET(E3="Debit";D3>O3;N3>3);"[!] OVD_BF";"OK")
```

Scoring : L1=4 | L2=4 | L_Overall=4 | Impact=4 → **16/25** Élevé

3.2.8 S8-A – Layering / Blanchiment (Credit vers Debit rapide)

Le cycle du blanchiment



[!

Précondition obligatoire] **Trier le dataset AVANT d'appliquer cette formule :**
Données → Trier → 1er : AccountID (Croissant) → 2ème : TransactionDate (Croissant)
Sans ce tri, la formule génère des faux positifs car elle compare des lignes sans rapport chronologique.

S8-A – Layering (Colonne AA) – après tri obligatoire

```
=SI(ET(E3="Debit";D3>500;B3=B2;E2="Credit";D2>500);"ALERT LAYERING";"OK")
```

Résultat : 229 cas | Moyenne Debit : 820$ | Credit précédent moyen : 778$

Scoring : L1=3 | L2=4 | L_Overall=4 | Impact=5 → **20/25** Très Élevé

3.2.9 S9-A – Account Farm / Botnet (IP Multi-Comptes)

Une adresse IP accédant à plusieurs comptes distincts ne peut pas correspondre à un comportement humain légitime. C'est la **signature d'un botnet** ou d'une ferme de comptes opérée automatiquement.

Indicateur	Valeur	Seuil d'alerte
IPs accédant à > 1 compte	**552**	≥ 2 comptes
Record : IP 200.136.146.93	**13 comptes**	Botnet confirmé
Enreg. BF depuis IPs multi-comptes	**1 288**	–
Comptes victimes totaux	**495**	–

S9-A – Account Farm / Botnet (Colonne AB)

```
=SI(NB.SI.ENS($H$3:$H$50001;H3;$B$3:$B$50001;"<>"&B3)>0;"[!]
IP_FARM";"OK")
```

Scoring : L1=4 | L2=4 | L_Overall=4 | Impact=5 → **20/25** Très Élevé

3.2.10 S10-A – Card Testing (Micro-transactions moins de 10dollar)

Le **card testing** consiste à effectuer de très petites transactions pour vérifier qu'une carte ou un compte volé est encore actif, avant de lancer des transactions frauduleuses importantes. C'est un **signal précurseur systématique** de fraude à plus fort montant.

S10-A – Card Testing (Colonne AC)

```
=SI(D3<10;"[!] CARD_TEST";"OK")
```

Résultat : 1 391 transactions < 10$ | AC00083 : 48 micro-transactions (record)

Scoring : L1=4 | L2=4 | L_Overall=4 | Impact=4 → **16/25** Élevé

3.2.11 S11-A – Money Mule Receiver (Comptes Credit-Only)

Un compte bancaire actif qui ne présente **aucune transaction Debit** est structurellement anormal. C'est le profil classique d'un **compte-réceptacle** dans un schéma de mule financière.

S11-A – Money Mule Receiver (Colonne AD)

```
=SI(NB.SI.ENS($B$3:$B$50001;B3;$E$3:$E$50001;"Debit")=0;"[!]
MULE_RECEIVER";"OK")
```

Résultat : 5 comptes avec 0 Debit sur toute la période

Scoring : L1=3 | L2=3 | L_Overall=3 | Impact=5 → **15/25** Élevé

3.2.12 S12-A – Impossibilité Géographique (2 Villes, Même Jour)

Un même compte dans deux villes distinctes le même jour, avec des devices et IPs différents, est **physiquement impossible** pour un seul individu. Cela prouve qu'au moins deux acteurs distincts utilisent le même compte.

Exemple documenté – AC00275, 11/06/2023 :

Transaction	Heure	Ville	Device
TX001954	17 :23 :00	Boston	D000451
TX038988	00 :00 :00	Oklahoma City	D000218
TX039508	00 :00 :00	Charlotte	D000678

S12-A – Impossibilité Géographique (Colonne AE)

```
=SI(NB.SI.ENS($B$3:$B$50001;B3;$F$3:$F$50001;"<>"&F3)>0;"[!]
GEO_IMPOSS";"OK")
```

Résultat : 1 102 cas | 355 comptes concernés

Scoring : L1=4 | L2=5 | L_Overall=5 | Impact=4 → **20/25** Très Élevé

3.2.13 S13-A – Anomalie Démographique (Student + Montants Élevés)

Occupation	Moyenne ($)	Maximum ($)	Paradoxe
Student	**313,15**	1 894,81	**La plus haute**
Doctor	291,21	2 060,59	–
Retired	297,94	1 768,79	–
Engineer	288,54	2 001,83	–

S13-A – Anomalie Student (Colonne AF)

```
=SI(ET(L3="Student";D3>500);"[!] STU_ANOMALIE";"OK")
```

Résultat : 2 670 transactions Student > 500$

Scoring : L1=3 | L2=3 | L_Overall=3 | Impact=4 → **12/25** Modéré

3.3 Les 9 Scénarios Croisés

Les scénarios croisés résultent de la **corrélation entre plusieurs signaux**. Ils représentent les événements de menace les plus complexes et souvent les plus graves.

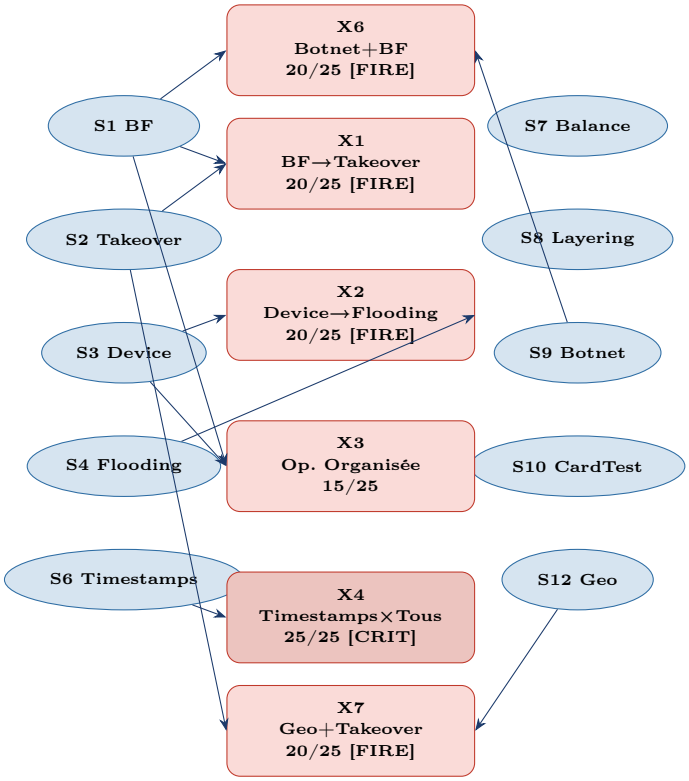


Table 3.1: Tableau récapitulatif des 9 scénarios croisés

ID	Scénario	Signaux	L1	L2	L_Ov.	Imp.	Score
X4	Timestamps × Tous (multiplicateur)	S6+Tous	5	5	5	5	25/25 Critique
X1	BF → Account Takeover	S1+S2	4	4	4	5	20/25 T.Élevé
X2	Device → Merchant Flooding	S3+S4	4	4	4	5	20/25 T.Élevé
X6	Botnet → BF Multi-Comptes	S9+S1	4	4	4	5	20/25 T.Élevé
X7	Geo Impossible + Takeover	S12+S2	4	4	4	5	20/25 T.Élevé
X3	Opération Organisée	S1+S3+S4	2	4	3	5	15/25 Élevé
X5	Card Testing → Flooding	S10+S4	3	4	3	5	15/25 Élevé
X8	Overdraft Forcé via BF	S7+S1	3	4	3	5	15/25 Élevé
X9	Layering + Merchant Flooding	S8+S4	2	4	3	5	15/25 Élevé

3.3.1 X4 – Le multiplicateur global : Timestamps × Tous

[CRIT

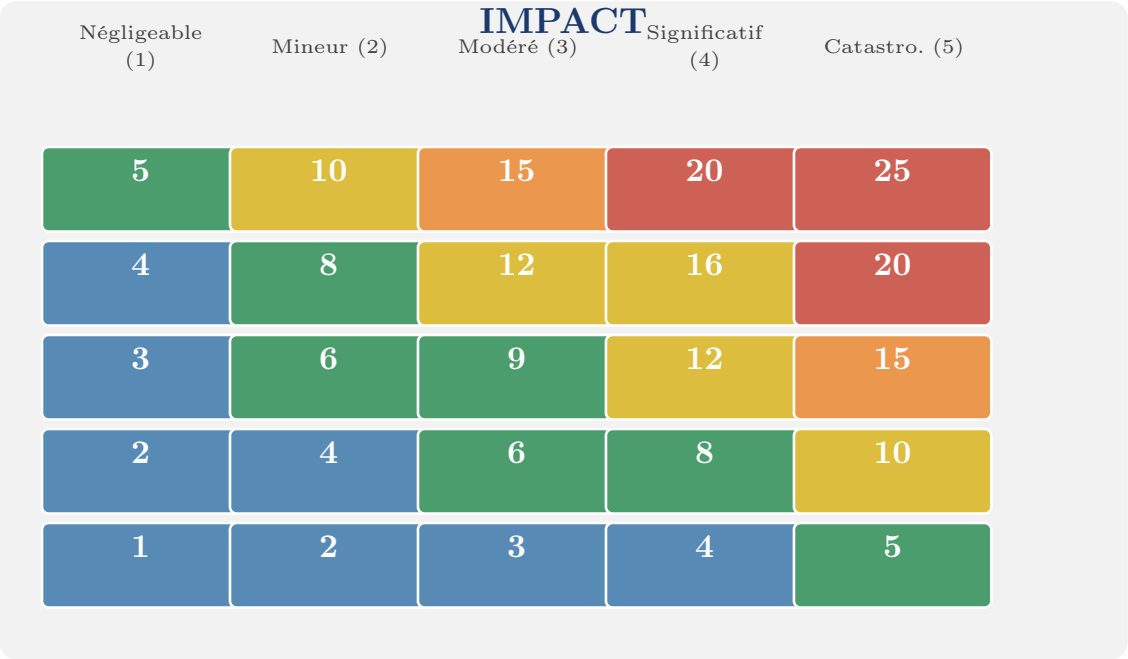
Scénario transversal critique] Ce scénario n'est pas une attaque isolée. C'est une **vulnérabilité amplificatrice** qui aggrave tous les autres scénarios. Sans timestamps précis, aucune anomalie détectée ne peut être **prouvée chronologiquement** devant un régulateur ou un tribunal.

Enregistrements BF sans timestamp précis :	**1 241**
Enregistrements Takeover sans timestamp :	**47 048**
Enregistrements Flooding sans timestamp :	**47 488**

CHAPITRE 4

Phase 3 – Communiquer les Résultats

4.1 La Matrice de Risques 5×5



4.1.1 Tableau récapitulatif des 26 scénarios

Table 4.1: Tous les scénarios classés par score décroissant

ID	Type	Scénario	L1	L2	L_Ov.	Imp.	Score
S6-A	Int.	Défaillance Timestamps	5	5	5	5	25 CRITIQUE
S7-A	Int.	Debit > AccountBalance	4	5	5	5	25 CRITIQUE

ID	Type	Scénario	L1	L2	L_Ov.	Imp.	Score
X4	Croisé	Timestamps × Tous	5	5	5	5	25 CRITIQUE
S12-A	Int.	Impossibilité Géographique	4	5	5	4	20 T.Élevé
S2-A	Int.	Account Takeover	4	4	4	5	20 T.Élevé
S4-A	Int.	Structuration Financière	4	4	4	5	20 T.Élevé
S8-A	Int.	Layering / Blanchiment	3	4	4	5	20 T.Élevé
S9-A	Int.	Account Farm / Botnet	4	4	4	5	20 T.Élevé
X1	Croisé	BF → Account Takeover	4	4	4	5	20 T.Élevé
X2	Croisé	Device → Merchant Flooding	4	4	4	5	20 T.Élevé
X6	Croisé	Botnet → BF Multi-Comptes	4	4	4	5	20 T.Élevé
X7	Croisé	Geo Impossible + Takeover	4	4	4	5	20 T.Élevé
S1-A	Int.	ATM Brute Force	4	4	4	4	16 Élevé
S1-B	Int.	Online Brute Force	5	3	4	4	16 Élevé
S3-A	Int.	Device Compromis	3	4	4	4	16 Élevé
S5-A	Int.	Bot Automatisé	4	3	4	4	16 Élevé
S7-B	Int.	Overdraft + Brute Force	4	4	4	4	16 Élevé
S10-A	Int.	Card Testing	4	4	4	4	16 Élevé
S11-A	Int.	Money Mule Receiver	3	3	3	5	15 Élevé
X3	Croisé	Opération Organisée	2	4	3	5	15 Élevé
X5	Croisé	Card Testing → Flooding	3	4	3	5	15 Élevé
X8	Croisé	Overdraft Forcé via BF	3	4	3	5	15 Élevé
X9	Croisé	Layering + Flooding	2	4	3	5	15 Élevé
S13-A	Int.	Anomalie Student	3	3	3	4	12 Modéré
S5-B	Int.	Session Longue Online	2	3	3	4	12 Modéré
S1-C	Int.	Branch Brute Force	3	3	3	4	12 Modéré

ID	Type Scénario	L1	L2	L_Ov.	Imp.	Score

4.2 Le Modèle OIR – Rapport de Communication

4.2.1 OIR-1 : Défaillance des Timestamps

OIR-1 – [!] CRITIQUE (25/25)

OBSERVATION : 47 488 sur 50 000 enregistrements (94,9%) ne disposent d'aucune heure de transaction précise. La composante horaire est absente et parsée à 00 :00 :00 par défaut. Les seules heures réelles (16h, 17h, 18h) concernent 2 512 enregistrements uniquement. AC00161 présente un solde figé à 421,93$ indépendamment des transactions – possible manipulation du registre.

IMPACT :

— Inutilisabilité légale : le registre ne peut servir de preuve lors d'un audit

— Non-répudiation impossible : aucun événement ne peut être daté avec certitude

— Non-conformité AML/RGPD : l'horodatage précis est une obligation légale

— Amplification de tous les autres risques : toutes les anomalies détectées perdent leur valeur probatoire

RECOMMANDATION :

1. Implémenter l'horodatage ISO 8601 (date + heure + fuseau) sur 100% des transactions
2. Auditer le pipeline ETL pour identifier le point de perte de l'heure
3. Règle de rejet : tout enregistrement sans heure complète est refusé
4. Reconstituer rétrospectivement depuis les logs systèmes si disponibles

Responsable : DSI / Équipe Data Engineering **Délai :** **IMMÉDIAT (0–72h)**

4.2.2 OIR-2 : Account Takeover et Impossible Geography

OIR-2 – [!] TRÈS ÉLEVÉ (20/25)

OBSERVATION : 471 comptes présentent des connexions depuis des DeviceID et IP différents sans blocage. 59 de ces comptes cumulent du Brute Force, exposant 1 584 876$ de transactions Debit. Parallèlement, 1 102 cas d'impossibilité géographique ont été détectés sur 355 comptes, dont AC00275 présent à Boston, Oklahoma City et Charlotte le même jour.

IMPACT :

— Compromission de comptes confirmée : des tiers non autorisés y accèdent

— Exposition financière directe : 1,58M$ sur les 59 comptes critiques

— Violation RGPD Art.33 : obligation de notification sous 72h si violation confirmée

RECOMMANDATION :

1. MFA obligatoire pour toute connexion depuis un nouveau device ou une nouvelle IP
2. Alerte SMS/email automatique au client à chaque device non enregistré
3. Règle géographique : même compte dans 2 villes > 100km le même jour → blocage + alerte
4. Invalider toutes les sessions actives lors de détection d'accès concurrent

Responsable : Équipe Sécurité IAM / RSSI **Délai :** **URGENT (< 1 semaine)**

4.2.3 OIR-3 : Structuration Financière et Blanchiment

OIR-3 – [!] TRÈS ÉLEVÉ (20/25)

OBSERVATION : 2 446 paires Account-Merchant avec plus de 5 transactions. 46 paires utilisent plusieurs canaux différents (contournement AML actif). Record : AC00398 → M091 : 42 transactions, 31 072$. Parallèlement, 229 cas de Layering (Credit > 500$ suivi de Debit > 500$) avec une moyenne de 820$ par Debit.

IMPACT :

— Violation AML : la structuration et le layering sont des infractions pénales

— Obligation TRACFIN/SAR non respectée

— Risque de sanction régulatoire : amende + suspension de licence bancaire

RECOMMANDATION :

1. Règle de vélocité : > 5 transactions vers même MerchantID / 30 jours → alerte AML
2. Soumettre les 46 paires multi-canaux à TRACFIN/FinCEN
3. Geler temporairement AC00398, AC00011, AC00241 pour investigation
4. Détecter Credit élevé suivi de Debit élevé dans une fenêtre de 48h

Responsable : Compliance Officer / Cellule AML **Délai** : **URGENT (< 1 semaine)**

4.2.4 OIR-4 : Botnet et Account Farm

OIR-4 – [!] TRÈS ÉLEVÉ (20/25)

OBSERVATION : 552 adresses IP accèdent à plusieurs comptes bancaires distincts. L'IP 200.136.146.93 accède à 13 comptes différents. Au total, 1 288 enregistrements combinent une IP multi-comptes avec du Brute Force, signature d'une infrastructure d'attaque coordonnée (botnet).

IMPACT :

— Attaque automatisée à grande échelle : 495 comptes potentiellement compromis

— Vol de données personnelles : obligation de notification RGPD Art.33

— Coût de remédiation élevé : investigation forensique requise

RECOMMANDATION :

1. Blacklister les 552 IPs au niveau du WAF (pare-feu applicatif)
2. Détection comportementale : IP accédant à > 2 comptes / 24h → blocage automatique
3. Déployer CAPTCHA adaptatif sur les endpoints d'authentification
4. Notifier le régulateur (CNIL / autorité bancaire) si violation confirmée

Responsable : RSSI / Équipe SOC / DPO **Délai :** **URGENT (< 1 semaine)**

4.2.5 OIR-5 : Signaux Élevés (Brute Force, Card Testing, Bots)

OIR-5 – Élevé (16/25)

OBSERVATION : Trois signaux Élevés complémentaires : (1) ATM Brute Force : 173 cas avec LA=5 + transaction Debit aboutie ; (2) Card Testing : 1 391 micro-transactions < 10$, AC00083 avec 48 occurrences ; (3) Bot Automatisé : 78 cas

avec durée fixe répétée (AC00108 : 12s exactes).

IMPACT :

— Absence de blocage après le seuil critique prouvée par les données

— Card testing = précurseur systématique de fraude à plus fort montant

— Signature de bot = infrastructure d'attaque professionnelle

RECOMMANDATION :

1. Blocage automatique après 3 échecs ATM + notification SMS
2. Alerte : > 3 micro-transactions < 10$ / 24h sur même compte → gel temporaire
3. Détecter les patterns de durée fixe répétés + challenge comportemental

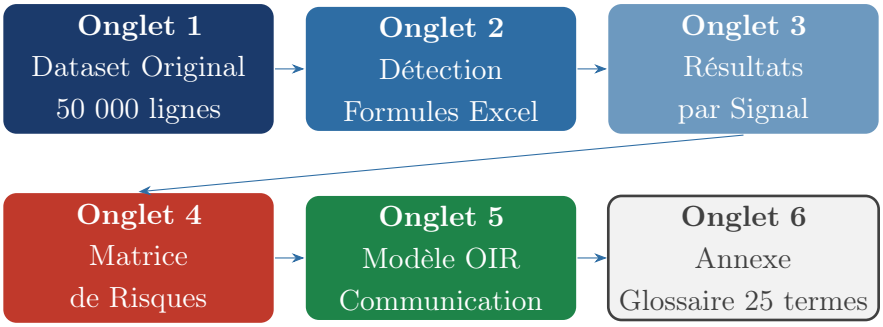
Responsable : Équipe Fraud Detection **Délai :** **HAUTE PRIORITÉ (< 1 mois)**

CHAPITRE 5

Livrables et Guide de Reproduction

5.1 Architecture du fichier Excel

Le fichier livrable `IT_Risk_Assessment_BankTransactions.xlsx` est organisé en 6 onglets interconnectés :



5.2 Guide de reproduction pas à pas

5.2.1 Étape 1 – Préparer le dataset (Onglet 1)

1. Ouvrir le fichier `.xlsx` dans Microsoft Excel (version française)
2. Vérifier que les colonnes correspondent bien à la nomenclature (ligne 2 = en-têtes)
3. Activer le filtre automatique : **Données** → **Filtre**
4. Figer les volets à la cellule A3 : **Affichage** → **Figer les volets**

5.2.2 Étape 2 – Créer les colonnes auxiliaires (Onglet 1, colonnes P à AF)

[TIP

Comment étirer une formule sur 50 000 lignes] **Méthode recommandée (Zone de Nom) :**

1. Saisir la formule en ligne 3 (ex : P3)
2. Cliquer sur la **Zone de Nom** (coin haut-gauche, affiche "P3")
3. Taper **P3 :P50001** puis appuyer sur **Entrée**
4. Appuyer sur **Ctrl+D** → la formule se copie sur toutes les lignes

Table 5.1: Toutes les formules de détection (Excel français)

Signal	Colonne	En-tête	Formule (à saisir en ligne 3)
S1-A	Col P	BF_ATM	=SI(ET(J3="ATM";N3>3;E3="Debit");"ALERT BF_ATM";"OK")
S1-B	Col Q	BF_Online	=SI(ET(J3="Online";N3>3);"ALERT BF_Online ";"OK")
S1-C	Col R	BF_Branch	=SI(ET(J3="Branch";N3>3);"ALERT BF_Branch ";"OK")
S2-A	Col S	TAKEOVER	=SI(NB.SI.ENS($B$3:$B$50001;B3;$G$3:$G$50001;"<>"&G3)>0;...
S3-A	Col T	DEV_MULTI	=SI(NB.SI.ENS($G$3:$G$50001;G3;$B$3:$B$50001;"<>"&B3)>0;...
S4-A	Col U	MERCH_FLOOD	=SI(NB.SI.ENS($B$3:$B$50001;B3;$I$3:$I$50001;I3)>5;...
S5-A	Col V	BOT_COURT	=SI(ET(M3<=24;N3>3;E3="Debit");"ALERT BOT_COURT";"OK")
S5-B	Col W	SESSION_LONGUE	=SI(ET(M3>292;J3="Online");"ALERT SESSION_LONGUE";"OK")
S6-A	Col X	TS_MANQUA	=SI(TEXTE(D3;"hh:mm:ss")="00:00:00";"ALERT TS_MANQUANT";"OK")
S7-A	Col Y	BAL_VIOLA	=SI(ET(E3="Debit";D3>O3);"ALERT BAL_VIOLATION";"OK")
S7-B	Col Z	OVD_BF	=SI(ET(E3="Debit";D3>O3;N3>3);"ALERT OVD_BF ";"OK")
S8-A	Col AA	LAYERING	=SI(ET(E3="Debit";D3>500;B3=B2;E2="Credit";D2>500);...
S9-A	Col AB	IP_FARM	=SI(NB.SI.ENS($H$3:$H$50001;H3;$B$3:$B$50001;"<>"&B3)>0;...
S10-A	Col AC	CARD_TEST	=SI(D3<10;"ALERT CARD_TEST";"OK")
S11-A	Col AD	MULE_RECEIVER	=SI(NB.SI.ENS($B$3:$B$50001;B3;$E$3:$E$50001;"Debit")=0;...
S12-A	Col AE	GEO_IMPOS	=SI(NB.SI.ENS($B$3:$B$50001;B3;$F$3:$F$50001;...
S13-A	Col AF	STU_ANOMALIE	=SI(ET(L3="Student";D3>500);...

[!

Attention – Signal S8-A uniquement] La formule S8-A (LAYERING) compare chaque ligne avec la ligne précédente. **Elle nécessite un tri préalable obligatoire du dataset :** Données → Trier → AccountID (Croissant) + TransactionDate (Croissant). Sans ce tri, la formule produit des faux positifs.

5.2.3 Étape 3 – Vérifier les volumes

Pour chaque colonne auxiliaire, utiliser la formule de vérification :

Formule de vérification générique

```
=NB.SI(P:P;"[!] BF_ATM") → remplacer P:P et "[!] BF_ATM" par la colonne
et valeur cibles
```

Signal	Formule de vérification	Résultat attendu
S6-A	`=NB.SI(X:X;"ALERT TS_MANQUANT")`	47 488
S7-A	`=NB.SI(Y:Y;"ALERT BAL_VIOLATION")`	1 708
S4-A	`=NB.SI(U:U;"ALERT MERCH_FLOOD")`	var.
S1-A	`=NB.SI(P:P;"ALERT BF_ATM")`	173
S5-A	`=NB.SI(V:V;"ALERT BOT_COURT")`	78
S8-A	`=NB.SI(AA:AA;"ALERT LAYERING")`	229
S10-A	`=NB.SI(AC:AC;"ALERT CARD_TEST")`	1 391
S1-B	`=NB.SI(Q:Q;"ALERT BF_Online")`	391
S1-C	`=NB.SI(R:R;"ALERT BF_Branch")`	482
S7-B	`=NB.SI(Z:Z;"ALERT OVD_BF")`	34
S5-B	`=NB.SI(W:W;"ALERT SESSION_LONGUE")`	373
S13-A	`=NB.SI(AF:AF;"ALERT STU_ANOMALIE")`	2 670

CHAPITRE 6

Glossaire et Annexes

6.1 Glossaire des termes et notions

NIST SP 800-30 *(Cadre réglementaire)* National Institute of Standards and Technology – Special Publication 800-30 Rev.1. Guide de référence américain pour l'évaluation des risques dans les systèmes d'information. Définit 4 phases : Prepare, Conduct, Communicate, Maintain. *Source : NIST, 2012.*

Threat Event (Événement de menace) *(NIST 800-30)* Tout événement pouvant causer des dommages aux informations et systèmes. Peut être intentionnel (attaque) ou non intentionnel (erreur humaine, défaillance). *Source : NIST SP 800-30, p.8.*

Likelihood of Initiation (L1) *(NIST 800-30)* Probabilité qu'un acteur tente d'initier une attaque. Prend en compte la motivation, les capacités et les opportunités. Échelle 1–5. *Source : NIST SP 800-30, p.23.*

Likelihood of Success (L2) *(NIST 800-30)* Probabilité que l'attaque réussisse si lancée, compte tenu des vulnérabilités et des contrôles en place. Échelle 1–5. *Source : NIST SP 800-30, p.23.*

Overall Likelihood (L_Overall) *(NIST 800-30)* Combinaison de L1 et L2 via la table de combinaison NIST. Représente la probabilité globale qu'un événement de menace se produise et aboutisse. *Source : NIST SP 800-30, p.24.*

Brute Force *(Cybersécurité)* Technique d'attaque consistant à tenter systématiquement des combinaisons de credentials. Dans ce dataset : LoginAttempts > 3 sur un AccountID non légitime. Le *Credential Stuffing* est une variante utilisant des listes de credentials volés. *Source : OWASP Testing Guide.*

Account Takeover (ATO) *(Cybersécurité / Fraude)* Compromission d'un compte par un tiers non autorisé. Confirmé par : même AccountID + DeviceID différent + IP Address différente. *Source : FFIEC Cybersecurity Guidelines.*

Structuration (Smurfing) *(AML / Conformité)* Fragmentation d'un montant important en petites transactions pour éviter les seuils de déclaration AML. Infraction pénale dans la quasi-totalité des juridictions. *Source : FATF Recommendation 20.*

Layering *(AML / Conformité)* Deuxième phase du blanchiment : après le placement, le layering brouille la piste en multipliant les transactions. Détecté ici par Credit élevé → Debit élevé immédiat. *Source : FATF Glossary.*

Money Mule *(AML / Conformité)* Personne dont le compte est utilisé pour transférer des fonds illicites. Le compte-réceptacle ne présente que des Credits. 5 comptes de ce type identifiés. *Source : Europol / FinCEN.*

Card Testing *(Fraude bancaire)* Micro-transactions (< 10$) pour vérifier qu'une carte volée est encore active, avant d'escalader vers des montants importants. *Source : Visa Fraud Prevention Guidelines.*

Botnet *(Cybersécurité)* Réseau de dispositifs infectés contrôlés à distance pour des attaques coordonnées. Signature : une IP accédant à de nombreux comptes distincts. *Source : ENISA Threat Landscape.*

Non-répudiation *(Sécurité de l'information)* Garantie qu'un acteur ne peut pas nier avoir effectué une action. Repose sur l'horodatage précis. Compromise ici par l'absence de timestamps sur 94,9% des enregistrements. *Source : ISO 27001 A.12.4.*

Audit Trail (Piste d'audit) *(Gouvernance / Conformité)* Enregistrement séquentiel et chronologique de toutes les actions sur un système. Doit être complet, intègre et horodaté. *Source : ISO 27001 A.12.4.1.*

KYC (Know Your Customer) *(Conformité bancaire)* Processus d'identification et de vérification de l'identité des clients. Inclut la vérification de la cohérence revenus / transactions. *Source : FATF Recommendations.*

SAR (Suspicious Activity Report) *(Conformité bancaire)* Déclaration de soupçon obligatoire soumise aux autorités (TRACFIN en France, FinCEN aux USA) en cas de transactions potentiellement liées au blanchiment. *Source : Bank Secrecy Act / LCB-FT.*

Impossible Geography *(Fraude bancaire)* Présence d'un même compte dans deux localisations géographiquement incompatibles dans un intervalle de temps trop court pour être physiquement possible. *Source : Mastercard / Visa Fraud Rules.*

Man-in-the-Middle (MITM) *(Cybersécurité)* Attaque où un tiers s'interpose dans la communication entre client et serveur, interceptant et modifiant les données. Indiqué par des sessions Online > 292s. *Source : OWASP MITM.*

AML (Anti-Money Laundering) *(Conformité bancaire)* Ensemble des procédures visant à prévenir le blanchiment d'argent. Obligation légale pour les institutions financières sous peine de sanctions. *Source : FATF / 4ème Directive AML (UE).*

Modèle OIR *(Communication des risques)* Framework de communication structurant les résultats en trois parties : Observation (ce que les données révèlent), Impact (conséquences si non traité), Recommandation (actions concrètes). Destiné à différentes audiences. *Source : Pratique professionnelle.*

6.2 Tableau de synthèse final – Exposition financière totale

Scénario	Exposition identifiée	Niveau
S4-A Structuration + X2 Device→Flooding	∼14 500 000$	Très Élevé
X1 BF → Account Takeover (59 comptes)	1 584 877$	Très Élevé
X3 Opération Organisée	1 536 131$	Élevé
S13-A Anomalie Student	∼1 340 000$	Modéré
S1-B+C+A Brute Force total	∼280 000$	Élevé
S7-A Violation de Solde (1708 cas)	Variable	Critique
EXPOSITION TOTALE ESTIMÉE	**> 16 000 000$**	**CRITIQUE**

6.3 Références réglementaires et bibliographiques

[1] NIST. (2012). *Guide for Conducting Risk Assessments – SP 800-30 Rev.1*. National Institute of Standards and Technology. `https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final`

[2] FATF/GAFI. (2023). *International Standards on Combating Money Laundering and the Financing of Terrorism & Proliferation*. Financial Action Task Force. `https://www.fatf-gafi.org`

[3] OWASP. (2023). *OWASP Testing Guide v4.2 – Authentication Testing*. Open Web Application Security Project. `https://owasp.org/www-project-web-security-testing-guide`

[4] ISO/IEC. (2022). *ISO/IEC 27001 :2022 – Information Security Management Systems*. International Organization for Standardization.

[5] FFIEC. (2016). *Cybersecurity Assessment Tool*. Federal Financial Institutions Examination Council. `https://www.ffiec.gov/cyberassessmenttool.htm`

[6] European Parliament. (2018). *General Data Protection Regulation (GDPR) – Regulation (EU) 2016/679*. Official Journal of the European Union.

[7] Europol. (2023). *Internet Organised Crime Threat Assessment (IOCTA)*. European Union Agency for Law Enforcement Cooperation.

[8] ENISA. (2023). *ENISA Threat Landscape 2023*. European Union Agency for Cybersecurity. `https://www.enisa.europa.eu`

FIN DU DOCUMENT

IT Risk Assessment – Analyse de Sécurité Bancaire

NIST SP 800-30 Rev.1 – 26 scénarios – 50 000 enregistrements

Ce document a été produit dans un cadre pédagogique et professionnel.
Toutes les analyses sont basées sur un dataset synthétique (Kaggle).
Les scénarios sont des hypothèses argumentées par les données observées.